

W-W World of Work

Guia Completo de Publicacao e Seguranca

Como publicar na internet, fazer atualizacoes e proteger contra invasores

Documento Tecnico | Versao 1.0 | Julho 2025

Confidencial - Uso interno

Sumario

1. Como Publicar o Site na Internet
2. Opcoes de Hospedagem (Vercel, AWS, VPS)
3. Passo a Passo: Publicacao na Vercel (Recomendada)
4. Como Fazer Atualizacoes Futuras
5. Seguranca: Protegendo contra Invasores
6. Firewall e Portas de Entrada
7. Autenticacao e Acesso Seguro
8. Monitoramento e Resposta a Incidentes
9. Checklist de Seguranca Final

1. Como Publicar o Site na Internet

Para que o site W-W World of Work fique acessível globalmente na internet, voce precisa de tres componentes fundamentais: um dominio proprio (como ww.jobs), uma plataforma de hospedagem que execute o Next.js, e uma configuracao de DNS que direcione o dominio para o servidor. O processo completo envolve desde a compra do dominio ate a configuracao de certificados SSL para conexao segura (HTTPS), passando pela implantacao do codigo-fonte no servidor de producao e pela validacao de que todas as 20 paginas de paises estao gerando corretamente o sitemap.xml e os metadados SEO para o Google.

Existem diversas opcoes de hospedagem disponiveis no mercado, cada uma com vantagens e desvantagens especificas. A escolha depende do seu orcamento, conhecimento tecnico e expectativa de trafego. Abaixo detalhamos as tres principais opcoes, com foco na recomendacao ideal para o seu caso.

1.1 Opcoes de Hospedagem

Plataforma	Custo Mensal	Dificuldade	Recomendacao
Vercel	Gratis a \$20	Facil	Melhor para iniciar
AWS / CloudFront	\$15 a \$100+	Media	Para escala global
VPS (DigitalOcean)	\$5 a \$50	Avancada	Controle total

2. Vercel: A Melhor Opcao para Iniciar

A Vercel e a plataforma criadora do Next.js e oferece a melhor integracao possivel com o seu projeto. Alem do plano gratuito ser suficiente para o inicio, ela fornece CDN global (o site carrega rapido em qualquer pais), certificado SSL automatico, deploy continuo (cada alteracao no codigo e publicada automaticamente), e suporte nativo a SSG (Static Site Generation) que ja configuramos no seu projeto com as 20 paginas de paises pre-geradas.

Com a Vercel, nao e necessario configurar servidores, instalar dependencias ou gerenciar infraestrutura. Voce faz o upload do codigo e a plataforma cuida de tudo: build, deploy, CDN, SSL e monitoramento basico. Isso e essencial para que voce possa se concentrar no negocio (cadastrar empresas, atrair candidatos) em vez de gastar tempo com operacao de servidor.

2.1 Passo a Passo: Publicacao na Vercel

- 1. Crie uma conta** em vercel.com usando seu GitHub, GitLab ou email.
- 2. Faça upload do projeto:** Va em 'New Project' e importe o repositório do GitHub. Se ainda não tem repositório, suba a pasta do projeto para o GitHub primeiro usando: **git init, git add ., git commit -m 'v1', git remote add origin URL, git push -u origin main.**
- 3. Configure o domínio:** Em Settings > Domains, adicione 'ww.jobs' (ou outro domínio que comprou). A Vercel guia a configuração DNS passo a passo.
- 4. SSL automatico:** A Vercel gera o certificado HTTPS automaticamente ao conectar o domínio. Nenhuma configuração extra necessária.
- 5. Deploy automatico:** Cada push para a branch 'main' do GitHub aciona um novo deploy automático na Vercel.

NOTA: O plano gratuito da Vercel inclui 100GB de banda mensal, SSL automatico, CDN global e previews automaticas para cada alteracao de código. Isso é mais do que suficiente para o lançamento.

2.2 Comprando um Domínio

O domínio é o endereço do seu site na internet. Para uma plataforma de empregos global, recomenda-se registrar um domínio .jobs, .careers ou .com curto e memorável. Registradores confiáveis incluem Namecheap (a partir de \$5/ano), Cloudflare Registrar (custo de atacado sem margem), e GoDaddy. Após a compra, configure os DNS apontando para a Vercel: crie um registro CNAME com nome '@' apontando para 'cname.vercel-dns.com' e um registro A com nome '@' apontando para '76.76.21.21'.

3. Como Fazer Atualizacoes Futuras

O processo de atualização do site segue um fluxo simples e seguro. Todas as alterações são feitas no código-fonte local, testadas, e depois enviadas para a Vercel via Git. Isso garante que você sempre tem um backup do código, pode reverter alterações se algo der errado, e mantém um histórico completo de todas as versões já publicadas.

3.1 Fluxo de Atualizacao

- 1. Edite o código localmente** no seu computador usando VS Code ou outro editor.
- 2. Teste localmente** executando 'npm run dev' e verificando as alterações no navegador em localhost:3000.
- 3. Commit e push:** Use git add ., git commit e git push para enviar ao GitHub.

4. Deploy automatico: A Vercel detecta o push e faz o deploy automaticamente em 1-2 minutos. Voce pode acompanhar o progresso no painel da Vercel.

3.2 Tipos de Atualizacao Comuns

- **Adicionar novos paises:** Edite `src/lib/countries.ts` para adicionar o pais, crie os 8 empregos em `src/app/api/jobs/route.ts`, e adicione as traducoes em `src/lib/i18n.ts`.
- **Atualizar vagas:** Modifique o array de jobs no arquivo `route.ts`. O `sitemap.xml` e os metadados SEO sao atualizados automaticamente.
- **Mudar visual:** Edite os componentes em `src/app/page.tsx` e `src/app/[country]/page.tsx`. O Tailwind CSS facilita qualquer alteracao visual.
- **Adicionar idiomas:** Expanda o array `LANGUAGES` e as traducoes em `src/lib/i18n.ts`.

ATENCAO: NUNCA edite o codigo diretamente na Vercel. Sempre faca alteracoes localmente, teste, e depois faca git push. Isso garante seguranca e rastreabilidade.

4. Seguranca: Protegendo contra Invasores

A seguranca do site W-W e dividida em camadas de protecao, cada uma responsavel por bloquear um tipo especifico de ataque. Nenhuma medida isolada e suficiente: a seguranca efetiva vem da combinacao de multiplas camadas. Pense como um edificio: portas trancadas, cameras, alarmes, seguranca 24h e seguro. Se uma camada falhar, as outras continuam protegendo.

4.1 Camada 1: Protecao de Infraestrutura (Vercel)

A Vercel ja fornece protecao de infraestrutura de nivel empresarial sem configuracao adicional. Isso inclui protecao contra ataques DDoS (quando milhoes de requisicoes sao enviadas para derrubar o site), WAF (Web Application Firewall) que bloqueia requests maliciosos, HTTPS forçado (todas as conexoes sao criptografadas), e isolamento entre projetos. Essas protecoes sao ativadas automaticamente e nao exigem nenhuma acao sua, mas e importante entender o que elas fazem para configurar as camadas seguintes corretamente.

- **DDoS Protection:** A Vercel absorve picos de trafego malicioso antes que atinjam seu site. Ataques de negacao de servico sao bloqueados na borda da rede.
- **WAF (Web Application Firewall):** Analisa cada request e bloqueia padroes conhecidos de ataque: injecao de SQL, XSS (cross-site scripting), e payloads maliciosos.

- **HTTPS Automatico:** Toda comunicacao e criptografada com TLS 1.3. Dados de usuarios (email, senhas, pagamentos) nunca trafegam em texto puro.
- **Isolamento:** Cada deploy roda em um ambiente isolado (serverless). Mesmo que um invasor consiga explorar uma vulnerabilidade, nao tera acesso ao sistema operacional do servidor.

OK: A Vercel e auditada conforme SOC 2 Type II, ISO 27001 e GDPR. O nivel de seguranca de infraestrutura e o mesmo usado por empresas como Uber, Netflix e Washington Post.

4.2 Camada 2: Headers de Seguranca HTTP

Headers HTTP sao instrucoes que o servidor envia ao navegador em cada resposta. Eles configuram barreiras de seguranca no proprio navegador do usuario, impedindo que o site seja usado como vetor de ataque contra seus visitantes. No seu projeto, alguns ja estao configurados no next.config.ts, mas precisam ser expandidos para protecao completa.

Header	Funcao	Status
X-Frame-Options	Impede que o site seja carregado em iframes de outros sites (evita clickjacking)	Configurado
Content-Security-Policy	Controla quais recursos o navegador pode carregar (scripts, imagens, fontes)	Precisa ajuste
X-Content-Type-Options	Impede o navegador de interpretar arquivos como tipo diferente do declarado	Precisa adicionar
Strict-Transport-Security	Forca HTTPS por 1 ano - impede ataques de degradacao de conexao	Precisa adicionar
Referrer-Policy	Controla quanto da URL anterior e enviada ao navegar para outro site	Precisa adicionar
Permissions-Policy	Controla quais APIs do navegador o site pode usar (camera, mic, geolocation)	Precisa adicionar

4.3 Camada 3: Content Security Policy (CSP)

A Content Security Policy (CSP) e a camada de seguranca mais poderosa no nivel do navegador. Ela define uma lista branca de fontes confiaveis para cada tipo de recurso: scripts, estilos, imagens, fontes e conexoes de rede. Se um invasor conseguir injetar um script malicioso no seu site (via XSS), a CSP impedira que o navegador o execute porque o script nao estara na lista branca. A CSP deve ser configurada no next.config.ts e e essencial para a seguranca do seu site.

A configuracao recomendada para o W-W inclui permitir scripts apenas do proprio dominio e da Vercel, estilos apenas inline e do proprio dominio, fontes apenas do Google Fonts e fonts do sistema, imagens de qualquer origem (necessario para as bandeiras dos paises e logos de empresas), e conexoes apenas para a propria API e servicos de analytics. Nunca use 'unsafe-inline' para scripts em producao, pois isso anula completamente a protecao contra XSS.

4.4 Camada 4: Autenticacao e Acesso Admin

Quando voce precisar de um painel administrativo para gerenciar vagas, usuarios ou configuracoes, a autenticacao deve seguir principios de seguranca rigorosos. Nunca implemente autenticacao propria (com senhas em texto puro ou criptografia caseira). Use sempre provedores de identidade estabelecidos e bibliotecas auditadas.

- **Autenticacao com NextAuth.js / Auth.js:** Biblioteca oficial do Next.js que suporta login com Google, GitHub, email/senha, e mais de 50 provedores. Gerencia sessoes, tokens JWT e cookies seguros automaticamente.
- **Clerk:** Solucao completa de autenticacao com UI pre-construida, verificacao de email em dois passos, autenticacao em duas etapas (2FA), e protecao contra brute force.
- **Senhas:** Se usar email/senha, armazene sempre com bcrypt ou argon2 (nunca MD5 ou SHA1). Exija senhas de no minimo 12 caracteres com maiusculas, minusculas, numeros e simbolos.
- **Sessoes:** Use cookies httpOnly, secure e sameSite=strict. Nunca armazene tokens de sessao no localStorage (vulneravel a XSS).

CRITICO: NUNCA armazene senhas em texto puro ou use hash simples (MD5, SHA1). Use sempre bcrypt (custo minimo 12) ou Argon2id. Uma unica senha comprometida pode destruir a reputacao de toda a plataforma.

4.5 Camada 5: Protecao da API e Dados

A API do seu site (/api/jobs) e o ponto de entrada para todos os dados. Ela precisa ser protegida contra abuso e ataques. As medidas essenciais incluem rate limiting (limitar o numero de requisicoes por IP por minuto), validacao de entrada (nunca confiar em dados enviados pelo usuario), CORS restritivo (permitir requests apenas do proprio dominio), e sanitizacao de queries para evitar injecao de SQL se no futuro conectar um banco de dados real.

- **Rate Limiting:** Limite a 100 requests por IP por minuto. Use a biblioteca 'rate-limiter-flexible' no Next.js. Isso impede ataques de forza bruta e abuso da API.
- **CORS:** Configure o header Access-Control-Allow-Origin para aceitar apenas 'https://ww.jobs' e nenhum outro dominio. Isso impede que sites maliciosos facam requests para sua API.

- **Validacao:** Use Zod ou Yup para validar todos os dados recebidos em APIs. Nunca passe dados do usuario diretamente para queries de banco de dados.
- **HTTPS Only:** Configure cookies com flag 'secure' para que so sejam enviados sobre HTTPS. A Vercel ja forza HTTPS, mas certifique-se de que nao ha rotas HTTP abertas.

4.6 Camada 6: Seguranca do Banco de Dados

Quando o site evoluir de dados mock para um banco de dados real (para armazenar usuarios, vagas, pagamentos), a seguranca do banco se torna critica. As melhores praticas incluem usar Prisma ORM (ja integrado ao Next.js) que automaticamente protege contra injecao de SQL, manter credenciais do banco em variaveis de ambiente (.env) nunca no codigo, usar conexoes SSL para o banco de dados, implementar backups automaticos diarios, e aplicar o principio do menor privilegio: o usuario do banco de dados deve ter acesso apenas as tabelas necessarias, nunca acesso de administrador.

- **Prisma ORM:** Gera queries parametrizadas automaticamente. Injecao de SQL e impossivel mesmo que o desenvolvedor tente.
- **Variaveis de ambiente:** DATABASE_URL, SECRET_KEY e outras credenciais ficam no arquivo .env que NUNCA e enviado ao GitHub (adicionar ao .gitignore). Na Vercel, configure como Environment Variables no painel.
- **Backups:** Configure backups diarios automaticos. Para PostgreSQL (recomendado), use o pg_dump automatizado ou o backup nativo do provedor (Vercel Postgres, Supabase, Neon).
- **Encriptacao em repouso:** Dados sensiveis (emails, pagamentos) devem ser criptografados no banco usando AES-256, nao apenas em transito (HTTPS).

5. Firewall e Portas de Entrada

O conceito de 'portas de entrada' na web moderna e diferente de um servidor tradicional. Em vez de portas de rede (porta 80, 443, 3306), os pontos de entrada de um site Next.js sao as rotas da API, os formularios, os endpoints de autenticacao e as integracoes com servicos externos. Cada um desses e uma potencial porta de entrada para um invasor, e cada um precisa de protecao especifica.

Ponto de Entrada	Risco	Protecao
/api/jobs	Scraping, DDoS, injeao	Rate limiting + CORS + cache
/api/auth/*	Brute force, sequestro de conta	Rate limiting + 2FA + logout

/api/payment/*	Fraude, interceptacao de dados	HTTPS + validacao + webhook signature
Formularios (newsletter, contato)	XSS, spam, injeao de header	Sanitizacao + captcha + rate limit
Upload de arquivos	Malware, RCE (remote code execution)	Validacao de tipo/tamanho + virus scan
Integracoes externas (Stripe, email)	Interceptacao de webhook, dados falsos	Webhook signature verification + HMAC

Alem desses pontos de entrada, e fundamental fechar portas que nao sao usadas. No `next.config.ts`, remova qualquer importacao ou dependencia que nao seja estritamente necessaria. Cada dependencia a mais e um potencial vetor de ataque. Revise periodicamente as dependencias com `'npm audit'` para identificar vulnerabilidades conhecidas, e atualize pacotes com `'npm update'` sempre que patches de seguranga forem disponibilizados.

6. Monitoramento e Resposta a Incidentes

Mesmo com todas as camadas de seguranga implementadas, e essencial ter monitoramento ativo para detectar e responder a incidentes rapidamente. O monitoramento permite identificar padroes suspeitosos (como um IP fazendo milhares de requests ou um usuario tentando acessar areas restritas) e tomar acao antes que um ataque cause danos significativos.

6.1 Ferramentas de Monitoramento Recomendadas

- **Vercel Analytics:** Gratuito e integrado. Mostra metricas de trafego, paginas mais visitadas, performance (Web Vitals) e dispositivos dos usuarios.
- **Sentry:** Detecta erros em tempo real. Quando um usuario encontra um erro, o Sentry captura automaticamente o stack trace, o navegador, a URL e os dados do usuario, e notifica voce instantaneamente. Gratuito para ate 5.000 eventos/mes.
- **Google Search Console:** Mostra como o Google ve o seu site, erros de rastreamento, posicoes nos resultados de busca e problemas de SEO. Essencial para monitorar o desempenho nos paises-alvo com alto desemprego.
- **Uptime Robot:** Monitora se o site esta no ar 24/7. Se o site ficar indisponivel, envia alerta por email, SMS ou Slack. Gratuito para ate 50 monitores.

- **Cloudflare (opcional):** Se mudar para um plano pago, o Cloudflare adiciona uma camada extra de WAF, bot protection e analytics de segurança.

6.2 Plano de Resposta a Incidentes

Todo site deve ter um plano claro do que fazer quando um incidente de segurança ocorre. O tempo entre a detecção e a resposta é crítico: quanto mais rápido você agir, menor o dano. O plano básico inclui quatro etapas: detecção (identificar o incidente via monitoramento), contenção (isolar a área afetada, por exemplo, desativando uma API comprometida), erradicação (remover a causa raiz, corrigir a vulnerabilidade) e recuperação (restaurar o serviço normal e verificar que a vulnerabilidade foi eliminada).

7. Acesso Seguro ao Painel Admin

Para que VOCE possa acessar o site de forma segura para gerenciar conteúdo, sem que ninguém consiga invadir, o painel administrativo deve seguir estas regras obrigatórias de segurança. O acesso deve ser restrito por IP (se possível), protegido por autenticação em duas etapas, e todas as ações administrativas devem ser logadas para auditoria.

- **URL secreta:** Não use '/admin' ou '/dashboard' - use um caminho aleatório como '/manage-x7k9q2' que só você conhece.
- **IP Whitelist:** Configure para que o painel admin só seja acessível do seu IP fixo. Na Vercel, use middleware para checar o IP antes de renderizar a rota.
- **2FA Obrigatório:** Autenticação em duas etapas com app autenticador (Google Authenticator, Authy). Nunca aceite apenas senha.
- **Sessão curta:** Configure sessões de no máximo 30 minutos de inatividade. Após isso, exigir novo login.
- **Logs de auditoria:** Registre quem acessou, quando, e o que fez. Se algo der errado, você sabe exatamente quem foi responsável.

8. Checklist de Segurança Final

Antes de publicar o site, verifique cada item deste checklist. Todos devem estar marcados como implementados ou planejados para o lançamento.

- ☐ **HTTPS forçado em todas as páginas** - Vercel faz automaticamente
- ☐ **Headers de segurança configurados** - Adicionar no next.config.ts

- [] Content Security Policy (CSP) ativa** - Configurar no next.config.ts
- [] Rate limiting na API** - Instalar rate-limiter-flexible
- [] CORS restritivo** - Configurar no middleware
- [] Autenticacao com 2FA** - Usar Clerk ou Auth.js + 2FA
- [] Senhas com bcrypt/argon2** - Nunca texto puro
- [] Variaveis de ambiente (.env)** - NUNCA no codigo
- [] .env no .gitignore** - Ja configurado
- [] Dependencias auditadas (npm audit)** - Rodar antes de cada deploy
- [] Sentry para erros** - Instalar @sentry/nextjs
- [] Google Search Console ativo** - Enviar sitemap apos publicar
- [] Uptime monitoring** - Configurar Uptime Robot
- [] Backup do banco de dados** - Automatizar backup diario
- [] Painel admin com URL secreta** - Nao usar /admin padrao
- [] Logs de auditoria ativos** - Registrar acoes admin

Este documento deve ser revisado mensalmente e atualizado sempre que uma nova camada de seguranca for implementada ou quando surgirem novas ameletacas no ecossistema Next.js/Vercel.